

GreenLeaf E-Commerce

Information Security Policy

Section: Access Control - Password Standard

Document Owner	Cameron Naidoo (Interim Security Lead)
Effective Date	23 June 2026
Review Cycle	Annually (or immediately upon major breach/ regulation change)
Classification	Internal / Confidential
Version	1.0

1. Purpose and Scope

This standard establishes the minimum requirements for all user accounts (employees, contractors, and third part vendors) accessing GreenLeaf E-Commerce systems, applications, and networks. This does not apply to non-interactive sysytem/service accounts unless explicitly stated.

2. Policy Requirements

To ensure robust authentication, all users must adhere to the following password construction and management standards, aligned with NIST Special Publication 800-63B (Digital identity Guideline)

A. Length over Complexity

Passwords shall be a minimum of **12 characters** in length. (NIST recommends 8 minimum, but industry standard in now 12-16).

Passphrases (eg., BlueBicycle!Roof#7) are strongly encouraged over short, complex jumbles.

B. Breach Checking

Password shall be checked against known data breach database (e.g., HavelBeenPwned) upon creation and periodically thereafter. Common dictionary words, keyboard patterns (e.g., qwerty), and variants of the company name are explicitly prohibited.

C. Uniqueness

Users shall not resumes a password across multiple accounts. Credential reuse between corporate and personal accounts is strictly forbidden.

D. Mandatory Multi-Factor Authentication (MFA)

Due to inherent weakness of static passwords, MFA (Utilising TOTP, hardware tokens, or biometrics) shall be enforced for all remote and privileged access. A password alone is not sufficient for system authoritarian

E. Enforcement and Compliance

Non-compliance with this policy may result in the immediate revocation of system access and is subject to disciplinary action in accordance with GreenLeaf's HR Code of Conduct. Compliance will be audited quarterly via automated scanning tools

Remote Access Policy

- Must use company VPN
- Must lock screen when stepping away
- Must not connect to public Wi-Fi without corporate VPN